

Cloud risk in business terms

How Onam puts a FAIR-style loss estimate on each finding — with every input shown, so a board can see what drives the number.

FAIR-style

EPSS × exposure

Sensitivity ×

Regulatory ×

Min · likely · max

THE ARGUMENT, IN ORDER

00	Executive summary	Severity tells you what is broken.
01	The FAIR model, briefly	The model is not ours.
02	The inputs	Every input is shown, and the ones that describe your business are yours to set.
03	From finding to estimate	The estimate sits on the finding, and attack paths raise it.
04	From one finding to a queue	A remediation queue you can argue with is worth more than one you have to trust.
05	Summary	Every number in this paper can be taken apart — that is the point of it.

00 Executive summary

Severity tells you what is broken. Business impact tells you what to fix first.

Security teams are drowning in "criticals". Boards are not asking how many — they are asking how much. This paper explains how Onam puts a FAIR-style loss estimate on each finding, so the conversation can move from a spreadsheet of severities to a ranked list in business terms.

FAIR — Factor Analysis of Information Risk — is published by The Open Group as the O-RT (Risk Taxonomy) and O-RA (Risk Analysis) standards. It decomposes risk into how often a loss happens and how large it is when it does. Onam applies that structure to every finding its engines raise, using data the platform already holds and inputs you can set, and shows the calculation next to the result.

The claim, precisely. Onam does not run a full FAIR analysis with simulation. It computes a FAIR-style estimate per finding — a minimum, likely and maximum figure — from stated inputs, so findings can be compared in one unit. It is an ordering tool, not a forecast.

01 The FAIR model, briefly

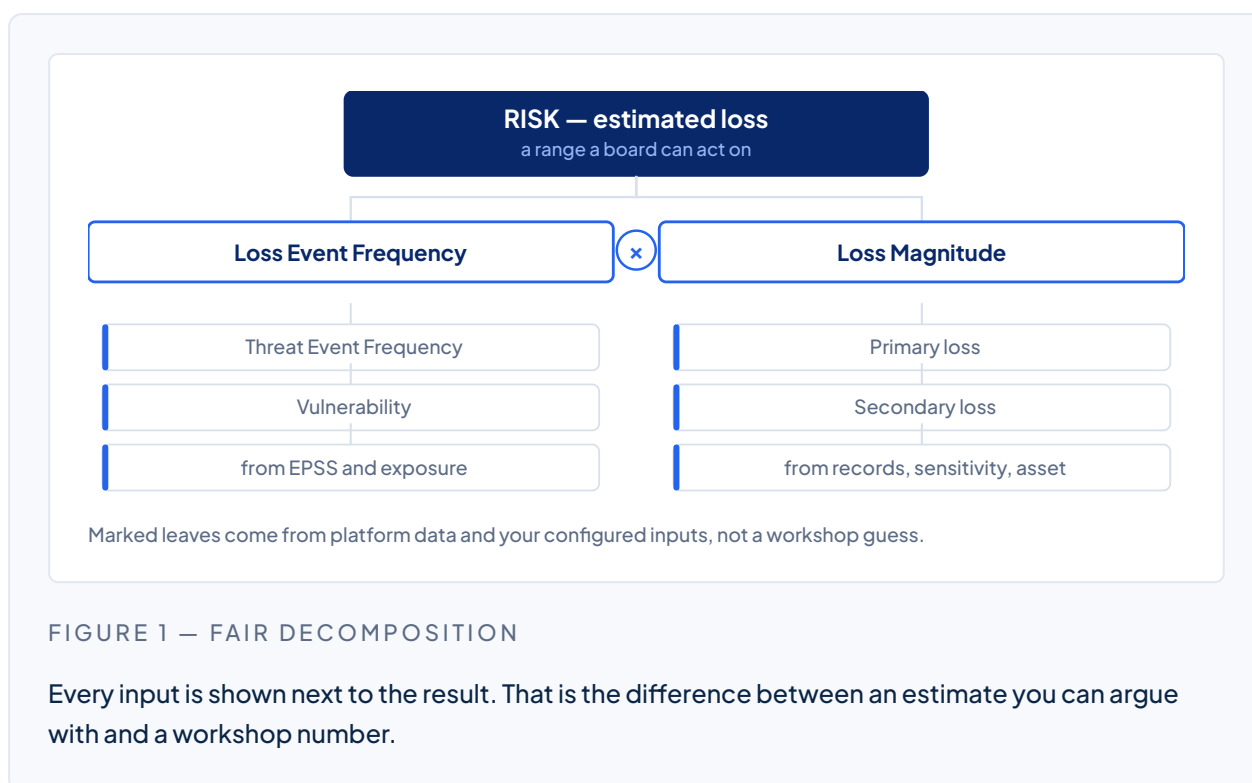
The model is not ours. FAIR is an open, published standard.

FAIR expresses risk as the product of how often a loss happens and how large it is when it does. Onam keeps that structure and fills each factor from platform data.

The strength of the structure is that each factor is inspectable. When Onam scores a finding, a reviewer can open the calculation and see which input drove the number — not a black-box score between 0 and 100.

02 The inputs

Every input is shown, and the ones that describe your business are yours to set.



A dollar figure is only as credible as the numbers behind it. These are the inputs Onam uses for each finding.

Input	Source / basis	Effect
Exploit likelihood	FIRST EPSS score for the vulnerability	Starting point for how often a loss event is expected
Exposure	Whether the resource is publicly reachable; attack-path signals	A public resource counts fully, an internal one at a fraction; findings on attack paths are raised
Records at risk and per-record cost	Defaults you can replace with your own figures	Base loss magnitude
Data-sensitivity weight	Onam data classification (DSPM)	Restricted ×3.0 → Confidential ×2.0 → Internal ×1.0 → Public ×0.1
Asset weight	Resource type; crown-jewel type from attack-path analysis	Keys, admin roles, data warehouses and similar weigh far more than ordinary resources
Regulatory weight and fines	Regulations that apply by region and data class (GDPR, HIPAA, PCI DSS, CCPA, SOX and others)	Highest applicable weight, not stacked; a separate fine range from each regulation's penalty structure, your record count and revenue

Inputs that describe your business — record counts, per-record cost, revenue, sensitivity weights — are configurable per tenant. Change one and the figure moves, which is the point of an inspectable model.

The honest limit. A quantified figure is an estimate, not an invoice. It is built on stated assumptions and defaults; it does not predict what a specific breach will cost. Anyone presenting it as a guarantee is misusing it, including us.

03 From finding to estimate

The estimate sits on the finding, and attack paths raise it.

1. **Find.** Engines raise findings across 7 clouds — posture, identity, data, vulnerability, threat detection.
2. **Connect.** Attack-path analysis marks findings that sit on a route to a crown jewel, and how many routes they sit on.
3. **Estimate.** Each finding gets a minimum, likely and maximum loss figure and a risk tier from the inputs above, with exposure raised for findings on attack paths.
4. **Explain.** The calculation inputs and the MITRE ATT&CK techniques involved are stored with the result.

04 From one finding to a queue

A remediation queue you can argue with is worth more than one you have to trust.

Ordered by estimated loss, the findings list becomes a queue in business terms: the largest contributors first, each with the inputs that put it there. Combined with attack-path choke points — the resource that appears on the most routes — it shows where one fix removes the most risk.

Because the same findings from the same 9,853 CSPM posture rules feed both the compliance and the risk views, a control gap and a high-loss finding are two readings of one underlying fact — not two systems to reconcile.

05 Summary

Every number in this paper can be taken apart — that is the point of it.

- FAIR is an open standard from The Open Group; Onam applies a FAIR-style estimate, not a full simulation.
- Likelihood starts from EPSS and exposure; magnitude from records, sensitivity, asset value and regulation.
- Inputs that describe your business are yours to set, and every input is shown with the result.
- Findings on attack paths are raised, so chained risk carries more weight than isolated risk.
- The output is a range with stated assumptions, not a prediction of a specific loss.